

SENTINAL SECURITY AUDIT REPORT

Target Scope: https://ginandjuice.shop | Scan Mode: SAFE | Auth: DEV_MODE | Date: September 04, 2026 at 07:45 UTC

Security Score	DAST Coverage	Critical Flaws	High Flaws	Total Findings
73.3/100	84.4% (FULL COVERAGE)	1	1	14

1. Target Connectivity & Blocking Diagnostics

Reachability	REACHABLE	TLS Protocol	TLSv1.2
Application Access	UNRESTRICTED	WAF / Bot Protection	None Detected
Finding Confidence	FULL	Coverage Status	FULL COVERAGE (84.4%)

Recommendation: Target is directly accessible.

2. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:** CRITICAL POSTURE**

The automated assessment of https://ginandjuice.shop identified immediate critical exposures requiring urgent remediation. A total of 14 findings were recorded, including 1 Critical and 1 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 14 (Critical: 1, High: 1, Medium: 4, Low: 8)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Vulnerable Dependency, Cloud Credentials, Session Management, Injection

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

4. Prioritized Vulnerability & Threat Inventory

Severity & Risk	Engine	Vulnerability & Threat Scenario	Location & Remediation
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	src/auth.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: lodash (4.17.15) - GHSA-29mw-wpgm-hmr9 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	package.json Fix: Upgrade lodash to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: django (3.2.0) - GHSA-2gwj-7jmv-h26r Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	requirements.txt Fix: Upgrade django to a secure version. Upgrade to latest version...

CRITICAL Risk: 100.0/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: AWS Access Key ID Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	src/auth.py Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..
LOW Risk: 25.5/100 Blast: Defense Degradation & Tr	DAST ZAP, HEADER_ANALYZER	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/ Fix: Ensure your application adds HttpOnly, Secure, SameSite to the cookie attributes...
LOW Risk: 23.2/100 Blast: Defense Degradation & Tr	DAST ZAP	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/catalog Fix: Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...
LOW Risk: 23.2/100 Blast: Defense Degradation & Tr	DAST ZAP	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/blog Fix: Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...
LOW Risk: 23.2/100 Blast: Defense Degradation & Tr	DAST ZAP	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/about Fix: Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...
LOW Risk: 23.2/100 Blast: Defense Degradation & Tr	DAST ZAP	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/my-account Fix: Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...
LOW Risk: 23.2/100 Blast: Defense Degradation & Tr	DAST ZAP	OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/login Fix: Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...
MEDIUM Risk: 49.9/100 Blast: Defense Degradation & Tr	WEB HEADER_ANALYZER	Missing HTTP Strict Transport Security (HSTS) Header Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/ Fix: Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS responses...
MEDIUM Risk: 49.9/100 Blast: Defense Degradation & Tr	WEB HEADER_ANALYZER	Missing Content Security Policy (CSP) Header Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/ Fix: Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; object-src 'none'`)...
LOW Risk: 22.2/100 Blast: Defense Degradation & Tr	WEB HEADER_ANALYZER	Missing X-Content-Type-Options Header Threat: Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..	/ Fix: Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser APIs...

LOW Risk: 30.2/100 Blast: Cloud & Third-Party Serv	WEB HEADER_ANALYZER	Missing Referrer-Policy Header Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	/ Fix: Configure `Referrer-Policy: strict-origin-when-cross-origin` or `no-referrer`...
--	-------------------------------	--	--

5. Strategic Remediation Playbook

- **Step-by-Step Remediation Actions:****
- ****Cloud Credentials:**** Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment variables or a Secret Vault.
 - ****Injection:**** Use parameterized queries (e.g. `cursor.execute('SELECT \* FROM users WHERE id = %s', (user\_id,))`) or an ORM with parameter binding.
 - ****Vulnerable Dependency:**** Upgrade lodash to a secure version. Upgrade to latest version.
 - ****Cryptographic Failures:**** Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS responses.